

Administrative Security Controls

1. Administrative Account Governance

Administrative accounts are considered high-risk and must be strictly controlled.

- Only authorized personnel may be granted administrator access.
- All administrative accounts must be uniquely assigned (no shared accounts).
- Access must follow the **principle of least privilege**.
- Administrative actions must be fully logged and monitored.

Administrators are responsible for:

- Managing user accounts (creation, suspension, reset)
- Enforcing security policies
- Monitoring system activity

However, administrators **must not have access to sensitive whistleblower data or decryption keys** to preserve confidentiality.

2. Password and Authentication Policy

Strong authentication is mandatory for all administrative users.

Password Requirements:

- Minimum length: 16 characters (recommended 18–24)
- Must include uppercase, lowercase, number, and special character
- No reuse of last 10 passwords
- Must not contain personal or dictionary-based words

Passwords must be securely stored using:

- Argon2id hashing algorithm
- Unique random salt per user

Multi-Factor Authentication (MFA):

- Primary: Hardware-based authentication (FIDO2 security keys)
- Secondary: Time-based One-Time Password (TOTP)

Weak methods such as SMS or email OTP are not permitted due to security risks.

3. Access Control and Role Separation

A strict **Role-Based Access Control (RBAC)** model must be enforced.

Administrator Permissions:

- Manage user accounts and roles
- Reset investigator credentials
- Configure system settings

Restrictions:

- No access to whistleblower reports
- No decryption capabilities
- No access to sensitive database tables

Investigator Permissions:

- Access only assigned cases
- Decrypt reports using private keys
- No administrative privileges

This separation ensures that no single role can compromise the system's confidentiality.

4. Login Security and Account Protection

To prevent brute-force and unauthorized access:

- Maximum 5 failed login attempts
- Account locked for 15 minutes after failure
- CAPTCHA enforced after 3 failed attempts
- Exponential delay applied to repeated attempts

- IP-based rate limiting implemented

All failed login attempts must be logged and monitored for suspicious activity.

5. Session Management Controls

Administrative sessions must be securely managed:

- Sessions expire after 10 minutes of inactivity
- Session ID regenerated after login
- Cookies must be:
 - Secure
 - HttpOnly
 - SameSite=Strict
- Re-authentication required for sensitive operations

All communication must be enforced over **TLS 1.3**.

6. Key Management Responsibilities

Administrators must enforce strict cryptographic key policies:

- Private keys stored in a Hardware Security Module (HSM)
- Separate encryption keys assigned per investigator
- Annual key rotation or immediate rotation upon role change
- Immediate revocation procedures for compromised keys

Administrators must not directly access or handle private keys.

7. Logging and Monitoring

Administrative actions must be continuously monitored.

Logged Events:

- Authentication attempts (success and failure)
- Privilege changes
- Administrative activities

Restrictions:

- No logging of:
 - Whistleblower content
 - Decrypted data
 - Sensitive metadata

Logs must be:

- Stored in an append-only system
- Protected with integrity monitoring

8. Account Recovery Procedures

Administrative account recovery must be highly secure:

- No password reset via email alone
- Identity verification required
- Mandatory re-enrollment of 2FA after reset
- Security team must be notified of all recovery actions

9. Infrastructure Oversight

Administrators are responsible for maintaining secure infrastructure:

- Separation of web server and database server
- Database encryption using AES-256
- Use of parameterized queries to prevent injection attacks
- Deployment of a Web Application Firewall (WAF)
- Regular patching and updates

Annual penetration testing must be conducted following guidelines from OWASP Top 10.

10. Security Principles Enforcement

Administrators must ensure the system adheres to core security priorities:

1. **Confidentiality** – Protection of whistleblower identity and data
2. **Anonymity** – No tracking or exposure of users
3. **Integrity** – Ensuring reports are not altered
4. **Availability** – Maintaining system uptime without compromising security